

Normies Pixel Market

Security Review Report (Public Edition)

Field	Value
Publisher	Trislit Consulting LLC
Date	3 October 2026
Engagement	Security review of Canvas V2 / Pixel Market cutover
Reviewed commit	36b382b0f1f2adfa7c5573478a03c5e5d338c292
Remediated commit	763d8982886a769017624950141360ecf70faf14
Scope	Storage V2, Canvas V2, Pixel Market, revenue pool, royalty splitter, deploy and migrate scripts, revshare builder, API/indexer market routes. Renderer skipped at the team's request.
Method	Manual review; Foundry suite; fix review of nine commits from the reviewed hash to 763d898, with directed tests against the new code
Classification	Public. Published with the Normies team's permission ahead of the Pixel Market launch.
Status	Draft for the team's sign-off. Not for release until the team confirms the remediated commit and the text below.

About this document

This is the public edition of the review I delivered to the Normies team. Findings were shared first. The team responded on 3 October 2026 with a remediation document covering every finding. I reviewed those changes on main (36b382b to 763d898) and confirmed the statuses below.

A security review is a point-in-time exercise. It reflects the named commits. It is not a guarantee that no defect exists.

For holders: I did not find a way for an outside attacker to drain market ETH, invent or steal #PIXEL, double-fill a listing, or overdraw the revenue pool.

1. Executive Summary

The question for launch is whether ETH and #PIXEL are safe, and whether the published cutover holds up.

They are. The market never holds fill ETH; seller and fees are paid in the same transaction. Storage V2 is the only #PIXEL ledger, and only the canvas role can mint or burn it. The pool cannot pay out more than an epoch reserved.

The original review had two Highs. Neither is an unprivileged drain.

- **C-H1.** Burning through Normies.burn leaves canvas state on that token ID. The team will not remint burned IDs. The site only burns through Canvas V2. Acknowledged.
- **D-H1.** One deployer key owned the whole V2 stack in the reviewed commit. The team split roles (owner, GUARDIAN, CONFIG, POSTER), put Admin / Treasury / Operations on separate Safes, and put the revshare job on a post-only key. They did not add an owner timelock. I accept that: the Safes are the control. Fixed.

Eight findings are fixed, one is partially fixed, and the rest are acknowledged with reasoning I agree with. The fix review found no new way for an outside attacker to take ETH or #PIXEL in the changed code. It did produce six operating notes for the team (Section 5), none of them a fund-loss bug.

Bottom line

Question	Answer
Can a random attacker steal ETH via a market or pool logic bug?	I found no evidence of one
Can a random attacker mint or steal #PIXEL?	No, not through the public API
Direct NFT burn leftover state?	Acknowledged. No remints; burn through Canvas V2 (C-H1)
One-key admin blast radius?	Fixed. Safes and roles; no owner timelock, by choice (D-H1)
Rewrite required before launch?	No

Severity and status

Severity	Original count	After remediation
Critical	0	0
High	2	1 acknowledged (C-H1), 1 fixed (D-H1)
Medium	5	4 fixed (C-M1, C-M2, C-M4, C-M5), 1 procedure adopted (C-M3)
Low	5	1 partially fixed (D-L4), 2 won't fix (C-L1, D-L2), 1 procedure adopted (D-L3), 1 acknowledged (D-L1)
Informational	13	3 fixed, rest acknowledged or documented

2. What I confirmed in the remediations

I read `NormiesAccess`, `HandoffOwnership.s.sol`, `reclaimExpired / releaseEscrow`, `finalizeMigration(expectedTotalAttached)`, the single delegation-seal path, `cancelEpoch / POST_DELAY`, the revshare guards, the indexer's cancel handling, and the API query parsing. I tested the new paths directly as an attacker would:

- a stolen post-only key trying to claim;
- re-posting after a cancel;
- cancel ordering;
- reclaiming an expired listing at the boundary second, and for someone else;
- front-running the migration gate.

Evidence at 763d898 (Forge 1.5.1, solc 0.8.33):

- the deployed contract sizes match the team's to the byte;
- the full Foundry suite, including the mainnet and Sepolia fork tests, gives 533 of 537. The four failures are fork tests whose fixtures conflict with behaviour already in place at the reviewed commit (an expired test signature, a listing under the price floor, a relist inside the cooldown), as the team stated;

- I re-ran the D-L1 check on mainnet myself: no burned Normie holds V1 action points, at the team's block or at a later one;
- the API server and indexer tests pass 55 of 55, and the code typechecks.

No new Critical, High or Medium in the changed code.

The named deviation stands: no owner timelock. Owner powers sit on the Admin and Treasury Safes, with the pixel ledger and the ETH under different Safes. GUARDIAN can pause and unpauses without the owner Safe. A posted epoch waits 24 hours before claims, and GUARDIAN can cancel it in that window. I agree with that layout for this launch, on the condition that the Safes are the multisigs the runbook describes. The handoff script checks that they are separate contracts, not their thresholds, so that is confirmed by hand at handoff.

The handoff still has to run after cutover and before unpauses. `MODE=check` is the on-chain proof.

3. Findings

Severity used here: Critical is unprivileged theft of principal with no recovery. High is material harm under realistic conditions. Medium is disruption or fairness, often procedure-mitigated. Low is limited impact. Informational is a design note.

3.1 High

C-H1: Direct NFT burn leaves canvas state; a remind inherits it

Canvas V2's burn detaches pixels and resets per-token state. `Normies.burn` does not. A later remind of that ID would hand leftover `#PIXEL` and paid canvas upgrades to the new owner.

Team: Acknowledged. Reminds are not in the product. Minters only mint the next sequential ID; the live minter has reached 10,000, which `Normies.mint` refuses. The site only burns through Canvas V2. They will not remind a burned ID unless canvas state is reset first.

Status: Acknowledged. I agree. The minters can't reach a burned ID. The Normies NFT owner still can, because the owner counts as a minter and supply is below 10,000. So this status depends on that key staying offline until it moves to a Safe (note FR-5).

D-H1: One hot deployer/owner key controls the whole V2 stack

In the reviewed commit every V2 contract was single-owner, and the runbook put the pool owner key on the API server.

Team: Fixed in c59f683. `NormiesAccess` splits owner / GUARDIAN / CONFIG / POSTER. Admin Safe owns storage, canvas, market, renderer. Treasury Safe owns the pool and splitter. Operations Safe is GUARDIAN and CONFIG. The revshare job key is POSTER only. Deployer ends with no roles and Lifebuoy rescue locked. `HandoffOwnership.s.sol` enforces distinct Safes and runs after both copies are finalized. No owner timelock: the team judged that a timelock would slow routine operations and incident response more than it would reduce risk at the current scale, and will revisit it if the value held grows.

Status: Fixed, with the documented deviation. I accept Safes instead of a timelock.

3.2 Medium

C-M1: Expired listings have no permissionless reclaim

Team: Fixed in 0fa4075. Anyone can call `reclaimExpired` once a listing expires. Pixels return to the seller only, with no new cooldown (`releaseEscrow`). Works while paused. Listings with no expiry are unchanged.

Status: Fixed. Confirmed in code.

C-M2: Revenue share pays on the owner's root, immediately

Team: Fixed in 29adcddc and c59f683. revshare run requires a second RPC, rebuilds the epoch there, re-checks the pool, then posts and reads back. Claims open 24 hours after post; GUARDIAN or owner can cancelEpoch until then.

Status: Fixed. A root is still trusted, but it is no longer immediate and irreversible.

C-M3: Replacing Canvas V2 strands unrevealed burns

Team: Procedure adopted. They only replace the canvas when pendingBurnCommitments is empty, pause first, and treat the pointer/role move as an Admin Safe action.

Status: Acknowledged, procedure adopted.

C-M4: finalizeMigration can close before every V1 balance is copied

Team: Fixed in 3448575. finalizeMigration(expectedTotalAttached) reverts unless totalAttached matches exactly. On mainnet the migrate script refuses TOKEN_IDS and any MAX_TOKEN_ID below 9999.

Status: Fixed. Confirmed in code.

C-M5: finalizeDelegations can empty-seal

Team: Fixed in e9411dd. seedDelegations and finalizeDelegations are gone. The only path is seedAndFinalizeDelegations.

Status: Fixed. Confirmed in code.

3.3 Low

ID	Title	Team	Mine
C-L 1	Burn reward params can change after commit	Won't fix. They only change tiers when no commitment is pending	Confirmed. Since the role split this is a CONFIG power on the Operations Safe (note FR-2)
D-L 1	V1 rewards on burned receivers migrate onto dead IDs	Acknowledged. Query at block 26,107,972: none found. They will re-run after V1 pause	Confirmed independently: none at 26,107,972 or 26,114,058
D-L 2	A long Canvas V2 pause forces minimum rolls	Won't fix. Planned pauses only with no pending burns; emergency pause accepts the fallback	Confirmed
D-L 3	MigrateLegacy reveal-check / pause race	Procedure: stop V1 burns on the site, confirm none pending, then pause	Confirmed
D-L 4	Revoking the market role freezes open listings	Partial: expired listings can be reclaimed. They will not revoke ROLE_MARKET while the market holds pixels	Confirmed

3.4 Informational

ID	Title	Team	Mine
C-I 1	#PIXEL on a Normie travels with the NFT	Acknowledged, intended	Confirmed

ID	Title	Team	Mine
C-I 2	Canvas delegate returns if the token does	Documented on the site	Confirmed
C-I 3	<code>setMinPricePerPixel(0)</code> allows fee-free fills	Acknowledged. CONFIG on Operations Safe; they will keep a real floor	Confirmed
C-I 4	Enlarge price underflow if the table is inverted	Acknowledged. They keep the table ascending	Confirmed
C-I 5	Overlay writers skip the canvas ceiling	Acknowledged, by design. Writers cannot touch balances	Confirmed
C-I 6	<code>releaseToken</code> sends non-WETH to the team	Procedure: convert the holders' share to ETH before the next epoch	Confirmed
D-I 1	Malformed market query params returned 500	Fixed (2daed85)	Confirmed
D-I 2	<code>revshare build</code> without <code>--epoch</code> could stamp the wrong ID	Fixed (29adcddc)	Confirmed
D-I 3	<code>setCooldown</code> accepts any address	Documented; Admin Safe only; meant for wrappers	Confirmed
D-I 4	Scoring counts Active listings after expiry	Acknowledged, by design. Escrow still belongs to the seller	Confirmed
D-I 5	Cutover copies V1 delegates for burned IDs	Acknowledged. Inert without a remind	Confirmed
D-I 6	NormiesZombie still reads V1 <code>getLevel()</code>	Acknowledged. Campaign complete; 21 claims done	Confirmed
D-I 7	<code>MIN_CLAIM_WINDOW</code> was 1 day	Fixed to 30 days (c658295)	Confirmed

4. Fund-loss paths ruled out

I did not find:

- Unprivileged drain of listing ETH or fee ETH
- Double fill, or a `batchBuy` that overfills the same listing
- Inventing `#PIXEL` without the canvas role
- Spending someone else's wallet pixels without an allowance
- A canvas or `delegate.xyz` delegate withdrawing or listing pixels
- A posted epoch paying out more than it reserved
- Owner withdrawal of ETH an epoch has reserved
- `migrateBatch` letting the caller choose amounts
- `reclaimExpired` sending pixels to anyone but the seller, or running while a listing can still be bought
- `cancelEpoch` after claims are open

- A post-only key claiming its own root before the 24-hour delay
- A stranger's migrateBatch pushing the migration total away from the original sum

5. Notes from the fix review

These came from reading the remediation code. None is a fund-loss bug, and none needs a contract change before launch.

ID	Severity	Note	Recommendation	Team
FR-1	Low	A cancelled epoch hands its block range back, so a compromised post-only key can post again straight after a cancel. What stops it is pausing posting and revoking the role	Incident step: cancel and pause in one Operations Safe transaction, then the Treasury Safe revokes the poster and the key is rotated. Page on any unexpected EpochPosted	Pending
FR-2	Low	The Operations Safe can't withdraw ETH or #PIXEL, but CONFIG can still zero a committed burn's reward (C-L1), and a long pause lowers rolls (D-L2)	Correct the "never moves value" wording if it is read as "cannot harm holders"; optionally give the burn-tier setters a floor or move them to the owner	Pending
FR-3	Info	Cancelling an older epoch and then the latest one skips the older block range permanently. No ETH is lost; that period's time-weighting is	Don't post while the latest epoch hasn't opened yet (or keep MIN_EPOCH_BLOCKS above a day)	Pending
FR-4	Info	The handoff check confirms three distinct Safes, not their thresholds or signer sets, and can't see role holders beyond the deployer	Add threshold and signer checks, and a replay of role events, to the check mode	Pending
FR-5	Info	The Normies NFT owner is still one key, and is the only path left to a remind (C-H1)	Move it to a Safe after the renderer and royalty steps	Pending
FR-6	Info	Some script and deploy docs still say a posted root "can never be cancelled"	Update the text	Pending

6. Residual risk

By design, after the remediations:

1. Admin, Treasury, and Operations Safes hold the remaining privilege. A compromised Safe threshold is still a compromise.
2. There is no owner timelock. Incident response is faster; a malicious Safe transaction is also faster.
3. A compromised post-only key can post a wrong root. The Operations Safe has 24 hours to cancel it and pause posting; if nobody acts in that window, the root pays out.
4. The Normies NFT owner key sits outside the Safe layout until it is moved (FR-5).
5. Revenue-share scores are computed off chain. The contract checks the reservation, not the fairness of the split.
6. The API and indexer are only as honest as the RPC they read.

These are accepted trust assumptions, not unfixed Critical bugs.

7. Conclusion

Escrow and pixel accounting held up on the reviewed commit. The team fixed the items that needed code, including the admin blast radius, expired-listing reclaim, migration seal, delegation seal, and the revenue-share post window. I reviewed 763d898, tested the new paths directly, and agree with their statuses.

With the handoff run and checked before unpause, the 24-hour post window monitored, and C-H1's no-remint policy kept, I am comfortable with this stack proceeding to launch.

Trislit Consulting LLC